

TEMPLATE P42 · QUARTERLY SECOND-LINE REPORT

# Quarterly second-line report

Reports each quarter to the board committee, or the committee that replaces it, on portfolio risks, incidents, nonconformities, exceptions, the inventory reconciliation and regulatory changes, with the decisions it is asked to take.

## IN THIS DOCUMENT

|    |                                     |    |                                                          |
|----|-------------------------------------|----|----------------------------------------------------------|
| 01 | Instructions for use                | 08 | Quarterly inventory reconciliation                       |
| 02 | Identification                      | 09 | Regulatory changes                                       |
| 03 | Key message and decisions requested | 10 | Expired conditions, lapsed acceptances and disagreements |
| 04 | Portfolio risks                     | 11 | Proposed decisions                                       |
| 05 | Incidents                           | 12 | Quality criteria                                         |
| 06 | Nonconformities                     | 13 | Approval and verification                                |
| 07 | Exceptions in force                 | 14 | Version control                                          |

**Legal notice and disclaimer.** SEVEN-G is a reference methodological framework provided "as is" and for information purposes only. It does not constitute legal, regulatory, financial or professional advice, nor does it guarantee compliance with any law or standard. References to general regulation (such as the EU AI Act, the GDPR, DORA or NIS2), to technical standards and to regulation specific to each sector or jurisdiction may be incomplete, may not apply to a particular case or may become out of date as a result of regulatory changes, interpretations or supervisory positions after their consultation date. **Each organisation that uses SEVEN-G is solely responsible for identifying the regulation that applies to it, verifying that it is current and certifying its own regulatory compliance,** with the appropriate qualified advice. This methodology is a generic, free aid shared with the community so that nobody has to start from scratch; each person or organisation can and should adapt it to its own use. It must not be inferred that its legally sensitive parts have been reviewed by legal counsel: those reviews, for each company or sector, are the ultimate responsibility of the company, consultant or organisation that uses it. Although every effort is made to keep it up to date, some regulation may have changed without being reflected here. To the fullest extent permitted by law, the author accepts no responsibility whatsoever for the effects of its application in any organisation or for its full applicability. The methodology does not grant certification of any kind. The author accepts no liability for any use made of this content or for any decisions taken on the basis of it. The data, figures, companies and cases in the examples are fictitious or illustrative.

**Why it matters.** The board committee oversees the effectiveness of control over AI, but it can only do so with an overall view that no single initiative provides: risks concentrating on one supplier or model, recurring incidents, overdue nonconformities, exceptions that never end, systems appearing outside the inventory or regulations that change. This report is the second line's contribution to C4 (30 §6.3) and turns that view into specific decisions for the committee.

01

Instructions for use

| Aspect                  | Guidance                                                                                                                                                                                                            |
|-------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| When it is used         | Once a quarter, before the board committee meeting (C4), with the same cut-off date as the board pack (60 §7.2). A partial report is brought forward if there is an S1 incident or a critical nonconformity.        |
| Who completes it        | The second-line coordinator for AI (accountable and responsible, 30 §6.3), with the AI Risk Owners, security, data protection and compliance; the AI Office provides the data from T01, T02, T06, T08, T09 and T21. |
| Who verifies it         | The third line is consulted (30 §6.3); the AI Committee sees it before it is sent and may add its position, without changing the content.                                                                           |
| Who decides or approves | The board committee oversees and decides on the proposals in section 11.                                                                                                                                            |
| Corporate cycle stage   | C4 · Oversight (quarterly). The fourth quarter feeds C5.                                                                                                                                                            |
| Tool                    | T06 (risks), T08 (incidents and nonconformities), T02 (inventory), T09 (suppliers), T21 (corporate use), T01 (exceptions and conditions) and T18 (decisions).                                                       |
| Reference document      | 30 §3.2 and §6.3; 32 §9; 33 §10–12; 34 §10.3; 37 §9; 60 §4.5–4.6.                                                                                                                                                   |

Completion rules:

- Business language: what may happen, whom it affects, what is being done and what decision is requested; no unprioritised technical listings (33 §12).

- Scales of the common specification §5.1 (risk), §5.5 (S1–S4 severity) and 01 §12 (minor, major and critical nonconformities).
- **Confirmed facts** are always distinguished from **assessments in progress** (37 §9).
- Regulatory changes carry a consultation date; the report does not constitute legal advice.

## 02

# Identification

| Field                            | Content | Guidance                                                                     |
|----------------------------------|---------|------------------------------------------------------------------------------|
| Period                           |         | AAAA-Qn.                                                                     |
| Data cut-off date                |         |                                                                              |
| Addressee                        |         | [Audit / Risk / Technology Committee] or the board if there is no committee. |
| Meeting at which it is presented |         | Minutes reference (P39).                                                     |
| Prepared by                      |         | Second-line coordinator for AI.                                              |
| Version                          |         |                                                                              |

## 03

# Key message and decisions requested

| Field                              | Content | Guidance                                                                                                                                                                          |
|------------------------------------|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Key message                        |         | Three lines using the response format: "Yes" · "Yes, with one condition: ..." · "Not yet, because ... is missing" · "No, because ...". Answers "is AI within the risk appetite?". |
| Changes since the previous quarter |         |                                                                                                                                                                                   |
| Decisions requested                |         | List with DEC code and one line; if there are none, this is stated expressly.                                                                                                     |

| Field                                     | Content                                                                                                                        | Guidance |
|-------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|----------|
| <i>(illustrative example) Key message</i> | Yes, with one condition: that the exit plan for the main model supplier, on which 62% of validated value depends, is approved. |          |

## 04

# Portfolio risks

## 4.1 Critical and High residual risks

| Risk<br>(initiative · Rnn) | Typical risk | Inherent level | Residual level  | Owner | Controls and effectiveness | Accepted by and validity | Next review |
|----------------------------|--------------|----------------|-----------------|-------|----------------------------|--------------------------|-------------|
| IA-AAAA-NNN · R01          | RT-XXX-NN    |                | High · Critical |       |                            |                          |             |

## 4.2 Concentration

Factors from 33 §10.1 and 14 §9; thresholds approved in C2.

| Factor              | Situation in the quarter | C2 threshold | Alert? (Yes · No) | Proposed measure |
|---------------------|--------------------------|--------------|-------------------|------------------|
| Model supplier      |                          |              |                   |                  |
| Platform and cloud  |                          |              |                   |                  |
| Critical function   |                          |              |                   |                  |
| Data                |                          |              |                   |                  |
| People              |                          |              |                   |                  |
| Sphere and ambition |                          |              |                   |                  |

## 4.3 Correlation: portfolio scenarios

Assessed with the matrix in 33 §4: sum of the economic impacts of the affected systems and worst impact on the other axes (33 §10.2).

| Scenario                                     | Systems affected | Aggregate economic impact | Worst non-economic impact | Level | Change from previous quarter |
|----------------------------------------------|------------------|---------------------------|---------------------------|-------|------------------------------|
| Unavailability of the main model supplier    |                  |                           |                           |       |                              |
| Change in behaviour of a common base model   |                  |                           |                           |       |                              |
| Vulnerability in a common agent component    |                  |                           |                           |       |                              |
| Regulatory reclassification of a type of use |                  |                           |                           |       |                              |
| Breach in a shared knowledge base            |                  |                           |                           |       |                              |

## 4.4 Key risk indicators

Thresholds approved in C2 (33 §11.2).

| Indicator                                      | Threshold                              | Value | Previous quarter | Status (Within · Outside) |
|------------------------------------------------|----------------------------------------|-------|------------------|---------------------------|
| Critical residual risks without board approval | 0                                      |       |                  |                           |
| High residual risks accepted                   | No growth for two consecutive quarters |       |                  |                           |
| Lapsed acceptances                             | 0                                      |       |                  |                           |
| Untested controls (High or Critical)           | < 10%                                  |       |                  |                           |
| Overdue treatment actions                      | 0 over 30 days                         |       |                  |                           |
| Materialised risks with no prior risk          | Downward trend                         |       |                  |                           |
| Drift outside threshold with no action         | 0                                      |       |                  |                           |
| Injection success in the last campaign         | Downward trend; 0 on sensitive actions |       |                  |                           |

| Indicator                         | Threshold             | Value | Previous quarter | Status (Within · Outside) |
|-----------------------------------|-----------------------|-------|------------------|---------------------------|
| Agents with excessive permissions | 0                     |       |                  |                           |
| Supplier concentration            | According to C2 limit |       |                  |                           |
| Regulatory classification overdue | 0                     |       |                  |                           |
| Unregularised unauthorised use    | Downward trend        |       |                  |                           |

| Field                                  | Content                                     |
|----------------------------------------|---------------------------------------------|
| Compliance with the risk appetite      | Within · Outside, with the limits exceeded. |
| Exposure to offensive AI (document 35) | Main indicators and events in the quarter.  |

05

# Incidents

Quarterly content of 37 §9 and 60 §4.6.

| Code         | System and initiative | Severity | Type | Date | Status | Notifications (regime, deadline met) | Lessons and actions |
|--------------|-----------------------|----------|------|------|--------|--------------------------------------|---------------------|
| INC-AAAA-NNN |                       | S1 · S2  |      |      |        |                                      |                     |

| S3 and S4 aggregate | Number | Main type | Median containment time |
|---------------------|--------|-----------|-------------------------|
|---------------------|--------|-----------|-------------------------|

| Field                                                                 | Content |
|-----------------------------------------------------------------------|---------|
| Regulatory notifications in the quarter and compliance with deadlines |         |
| Supplier incidents                                                    |         |
| Systemic lessons                                                      |         |

# Nonconformities

| Code        | Requirement not met | Type             | Scope | Status | Deadline | Overdue? | Corrective action |
|-------------|---------------------|------------------|-------|--------|----------|----------|-------------------|
| NC-AAAA-NNN |                     | Critical · Major |       |        |          | Yes · No |                   |

Critical: always individually. Major: individually if open beyond the deadline; aggregated otherwise. Minor: number only.

| Summary               | Critical | Major | Minor |
|-----------------------|----------|-------|-------|
| Open                  |          |       |       |
| Overdue               |          |       |       |
| Closed in the quarter |          |       |       |

# Exceptions in force

Summary of the P40 register (30 §7.4).

| Code         | Type | Requirement affected | Risk level with measures | Approved by | Expiry | Status             |
|--------------|------|----------------------|--------------------------|-------------|--------|--------------------|
| EXC-AAAA-NNN |      |                      |                          |             |        | In force · Expired |

# Quarterly inventory reconciliation

Result of the reconciliation in 32 §9, carried out by the AI Office.

| Source checked                                                                    | Differences found | Treatment | Nonconformities opened |
|-----------------------------------------------------------------------------------|-------------------|-----------|------------------------|
| Application and enterprise architecture register                                  |                   |           |                        |
| Contracts, purchases and renewals                                                 |                   |           |                        |
| AI supplier register (T09) and ICT third-party register (DORA , where applicable) |                   |           |                        |
| Cloud billing and model API consumption                                           |                   |           |                        |
| Code repositories and data platforms                                              |                   |           |                        |
| Record of processing activities (GDPR )                                           |                   |           |                        |
| Browsing, data loss prevention and device management                              |                   |           |                        |
| Expense claims and corporate cards                                                |                   |           |                        |
| Supplier release notes                                                            |                   |           |                        |
| Communications, surveys and audits                                                |                   |           |                        |

| Field                                                | Content                                        |
|------------------------------------------------------|------------------------------------------------|
| Systems registered as a result of the reconciliation |                                                |
| Systems in production without a <i>gate</i> detected | Each one is a critical nonconformity (01 §12). |

09

Regulatory changes

Register of mapping changes (34 §10.3).

| Change | Official source and consultation date | Initiatives or systems affected | Step reached (1–8 of 34 §10.3) | Approved by the committee (Yes · No · Not required) | Pending action |
|--------|---------------------------------------|---------------------------------|--------------------------------|-----------------------------------------------------|----------------|
|--------|---------------------------------------|---------------------------------|--------------------------------|-----------------------------------------------------|----------------|

# Expired conditions, lapsed acceptances and disagreements

| Type                                      | Reference         | Body that imposed it | Expiry date | Treatment                                  |
|-------------------------------------------|-------------------|----------------------|-------------|--------------------------------------------|
| Expired <i>gate</i> condition             | P29               |                      |             | Outcome becomes Iterate (01 §7.4, rule 4). |
| Expired board decision condition          | DEC-AAAA-NNN      |                      |             | The body is informed (62 §10.3).           |
| Lapsed risk acceptance                    | IA-AAAA-NNN · Rnn |                      |             | The risk blocks the <i>gate</i> again.     |
| Disagreement with the AI Committee (E-13) |                   |                      |             | Proposed resolution.                       |

# Proposed decisions

Each proposal with the decision sheet of 60 §5.1.

| Code         | What is requested | Type                                         | Second-line response | Options | What happens if no decision is taken |
|--------------|-------------------|----------------------------------------------|----------------------|---------|--------------------------------------|
| DEC-AAAA-NNN |                   | Approve · Accept a risk · Take note · Assign |                      |         |                                      |

# Quality criteria

| # | Check                                                                                   | Status                                   |
|---|-----------------------------------------------------------------------------------------|------------------------------------------|
| 1 | Critical and High risks, concentration and portfolio scenarios are up to date (33 §10). | Met · Not met · Not applicable · Pending |

| # | Check                                                                                            | Status |
|---|--------------------------------------------------------------------------------------------------|--------|
| 2 | All key risk indicators have a value and a threshold approved in C2, or are stated as "no data". |        |
| 3 | S1 and S2 incidents and critical nonconformities are reported individually (37 §9; 60 §4.6).     |        |
| 4 | The exceptions in force match the P40 register.                                                  |        |
| 5 | The inventory reconciliation was carried out in the quarter with all the sources in 32 §9.       |        |
| 6 | Each regulatory change has an official source and a consultation date.                           |        |
| 7 | The proposed decisions can be approved or rejected exactly as written.                           |        |
| 8 | Confirmed facts are distinguished from assessments in progress.                                  |        |

## 13

# Approval and verification

| Function                      | SEVEN-G role                   | Name and position | Date | Signature or reference       |
|-------------------------------|--------------------------------|-------------------|------|------------------------------|
| Prepares                      | Second-line coordinator for AI |                   |      |                              |
| Provides data                 | AI Office                      |                   |      |                              |
| Is consulted                  | Third line                     |                   |      |                              |
| Sees it and adds its position | AI Committee                   |                   |      |                              |
| Oversees and decides          | Board committee                |                   |      | Meeting and resolution (P39) |

Segregation of duties: the second line reports independently of the areas that sponsor the portfolio; the AI Committee may add its position but does not change the report.

# Version control

## Completed document

| Version | Date | Author | Changes |
|---------|------|--------|---------|
|---------|------|--------|---------|

## Template

| Version    | Date       | Changes                                                                                                                                                                                                         |
|------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>0.1</b> | 19-09-2026 | First version. Brings together the quarterly information on risks (33 §10–12), incidents and nonconformities (37 §9), exceptions (30 §7.4), inventory reconciliation (32 §9) and regulatory changes (34 §10.3). |

# External sources cited

Links to the official or primary source, checked before publication. Always verify the version in force on the date of use.

**Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)** · <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> · Parlamento Europeo y Consejo de la UE · 27-04-2016

**Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector (DORA)** · <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng> · Parlamento Europeo y Consejo de la UE · 14-12-2022